

Risk-Scoring Report — Dependency Backlog

Project: **vulnerable-invoice-service** · Stage 2 (Weighted Risk Model) · Generated 2026-06-29 · Branch: `fix/depSCAN-20260629-065427`

Scoring Model

Factor	Weight
CVE Severity (CVSS)	50%
Exposure (scope × depth)	30%
Business Criticality	20%

Band thresholds: CRITICAL ≥ 8.0 · HIGH 6.0–7.9 · MEDIUM 3.0–5.9 · LOW < 3.0

Pre-Remediation Ranked Backlog

#	Coordinate	Risk Score	Band	Top CVE	CVSS	CVEs	Fix
1	org.apache.logging.log4j:log4j-core:2.14.1	9.0	CRITICAL	CVE-2021-44228	10.0	7	2.17.1 ✓
2	com.fasterxml.jackson.core:jackson-databind:2.9.8	9.0	CRITICAL	CVE-2020-8840	9.8	55	2.13.4.2 ✓
3	org.apache.logging.log4j:log4j-api:2.14.1	9.0	CRITICAL	CVE-2021-44228	10.0	2	2.17.1 ✓
4	mysql:mysql-connector-java:8.0.30	8.2	CRITICAL	CVE-2023-22102	8.3	1	8.0.33 ✓
5	com.fastxml.jackson.core:jackson-databind:2.9.8	8.0	CRITICAL	TYPOSQUAT	—	0	REMOVED ✓
6	commons-io:commons-io:2.4	6.5	HIGH	CVE-2024-47554	7.5	2	2.15.1 ✓
7	com.google.guava:guava:24.1.1-jre	6.3	HIGH	CVE-2023-2976	7.1	2	32.0.0-jre ✓
8	org.apache.commons:commons-lang3:3.4	5.8	MEDIUM	CVE-2025-48924	6.5	1	3.14.0 ✓

Result: all 8 items remediated. 0 CRITICAL, 0 HIGH in targeted set.

Post-Remediation Residual Risk

All targeted items fully cleared. Residual findings below are newer advisories that require further major version jumps. All are flagged MAJOR_REVIEW.

Coordinate	Residual Advisory	Severity	Notes
mysql:mysql-connector-java:8.0.33	GHSA-m6vm-37g8-gqvh	HIGH	No fix version in gype DB; migrate to <code>com.mysql:mysql-connector-j:8.3+</code>
jackson-databind:2.13.4.2	GHSA-j3rv-43j4-c7qm, GHSA-rmj7-2vxq-3g9f	HIGH	Fix: 2.18.8 — major version jump, human review required
log4j-core:2.17.1	GHSA-3pxv-7cmr-fjr4, GHSA-vc5p-v9hr-52mj	MEDIUM	Fix: 2.25.3/2.25.4 — API changes, human review required

jackson-databind:2.13.4.2	GHSA-3wrr-7qpf-2prh, GHSA-hgj6-7826-r7m5, GHSA-5jmj-h7xm-6q6v	MEDIUM	Fix: 2.14.0–2.18.9 — major version, human review required
commons-lang3:3.14.0	GHSA-j288-q9x7-2f5v	MEDIUM	Fix: 3.18.0 — safe minor bump, schedule follow-up PR

Remediation Coverage

Band	Before	After (auto-fixed)	Residual
CRITICAL	5	0	0
HIGH	2	0	2 (MAJOR_REVIEW)
MEDIUM	1	0	5 (4 MAJOR_REVIEW + 1 follow-up)
Supply-chain	2	0	0

Machine-readable source: `depSCAN-risk-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.